

GENERAL DATA PROTECTION REGULATION (GDPR)

FRANCO ARCIERI

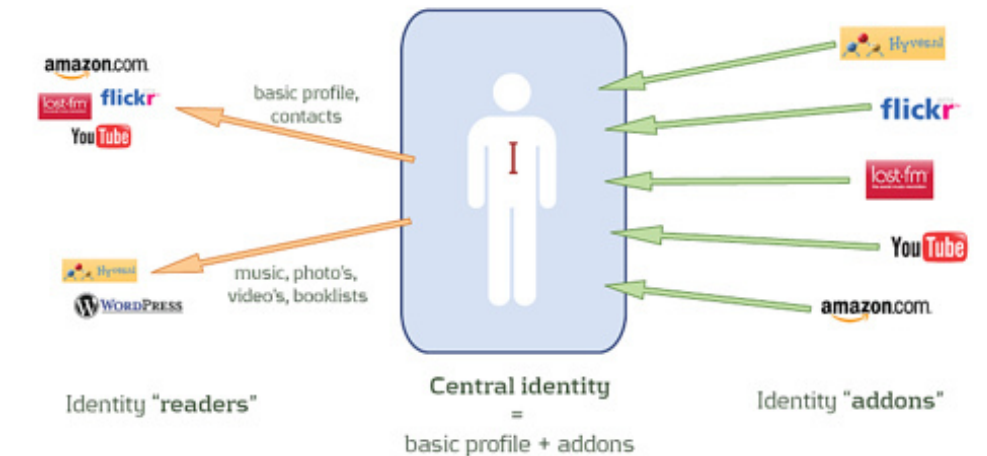
Temi trattati

- Contesto del GDPR - contiene informazioni su altre direttive e regolamenti relativi al GDPR per fornire dettagli sul suo contenuto più ampio
- Informazioni personali - ribadisce cosa si intende per informazioni personali e quindi cosa è coperto dal GDPR
- Principi del GDPR - identifica alcuni dei principi chiave su cui si basa il GDPR e che influenzeranno il suo funzionamento e le disposizioni particolari del GDPR volte a dare attuazione a tali principi.
- Attuazione e funzionamento del GDPR - si discutono gli approcci per rendere operativo il GDPR all'interno delle organizzazioni e le modifiche necessarie al sistema IT
- GDPR e outsourcing - contiene dettagli sul tema specifico dell'outsourcing e dell'impatto del GDPR
- Governance dei dati: inserisce il GDPR in un contesto più ampio di governance dei dati.
- Etica dei dati - qui si discute brevemente la questione più ampia dell'etica dei dati nel contesto del GDPR.



IDENTITY MANAGEMENT

- Cosa è definibile come identità?
 - il computer
 - un certificato digitale
 - il browser
 - lo smartphone
 - un indirizzo di posta elettronica
- Il rapporto tra lo strumento e la persona
- Protezione di una identità: privacy, profiling, etc. (il caso della genetica).
- Riconoscimento, autenticazione, non ripudiabilità
 - la firma digitale che scade
- Tracciatura



Requirements

- * Central identity
- * Identity standards
- * Data exchange standards

Central identity addons & readers
Marc Fontijn - marcfontijn.com - 2007

PRINCIPALI DEFINIZIONI

L' Articolo 4 del **General Data Protection Regulation** descrive le definizioni fondamentali per comprendere l'applicazione del Regolamento UE

- Dato Personale
- Trattamento
- Pseudoanonimizzazione
- Profilazione on line
- Consenso esplicito dell'interessato
- Titolare e Responsabile del trattamento
- Responsabile della protezione dati (Data Protection Officer)
- Valutazione d'Impatto Privacy (DPIA)
- Violazione dei dati personali (Data Breach)
- Trattamento transfrontaliero
- Norme vincolanti d'impresa

Dato personale

- Dato personale è qualsiasi informazione (nome, codice fiscale, immagine, voce, impronta digitale, traffico telefonico) concernente una persona fisica identificata o identificabile, anche indirettamente, oppure informazioni riguardanti una persona la cui identità è nota o può comunque essere accertata mediante informazioni supplementari (Convenzione 108, art. 2, lett. a) e Direttiva sulla protezione dei dati, articolo. 2, lett. a)).
- La persona a cui si riferiscono i dati soggetti al trattamento si definisce "interessato".

Dato personale

- Qualsiasi informazione che possa essere utilizzata per identificare una persona vivente - direttamente e indirettamente - o che la riguardi.
- Che cosa significa?
 - Può trattarsi di: nome, numero di identificazione o dati di localizzazione, come l'indirizzo IP.
 - Potrebbe anche includere altre informazioni che portano all'identificazione di un individuo (che potrebbero essere: fisiche, genetiche o culturali).
- Occorre prestare maggiore attenzione ai dati personali sensibili, ad esempio dati sulla salute, convinzioni religiose, ecc.

CATEGORIE DI DATI

- dati identificativi,
- dati soggetti a trattamento speciale (dati sensibili),
- dati giudiziari,
- dati anonimi, pseudonimi e minimizzati

DATI SENSIBILI (art.9)

- L'origine razziale ed etnica;
- Le convinzioni religiose o filosofiche;
- Le opinioni politiche;
- L'adesione a partiti, sindacati, associazioni a carattere religioso, politico o sindacale;
- Dati biometrici
- Dati genetici
- Lo stato di salute e la vita e l'orientamento sessuale

DATI GIUDIZIARI (art. 10)

- Provvedimenti di cui al casellario giudiziario e all'anagrafe delle sanzioni amministrative dipendenti da reato (D.lgs.231/2001)
- Condanne penali e ai reati o a connesse misure di sicurezza
- La semplice qualità di imputato o indagato ai sensi del codice di procedura penale

Le origini del GDPR

- Il 25 maggio 2018 è diventato operativo il regolamento (UE) n.2016/679, meglio noto come regolamento generale sulla protezione dei dati, in inglese General Data Protection Regulation – GDPR.
- La spinta propulsiva a cercare una legislazione moderna ed aggiornata rispetto al tempo che stiamo vivendo è chiaramente esplicitata nei Considerando 6,7 e 11 del regolamento.

REGOLAMENTO (UE) 2016/679



Disciplina unica in tutti gli Stati a protezione
dei cittadini europei anche in Extra-UE

DATI PERSONALI

Cosa sono?



La data economy



Quarta rivoluzione industriale: i dati sono il nuovo petrolio

16 Marzo 2021 / in [Digital Marketing](#)

Clive Humby, data scientist e matematico inglese, nell'ormai lontano 2006 coniò lo slogan **"I dati sono il nuovo petrolio"**.

Così come il petrolio ha permesso lo sviluppo socio-economico mondiale tra il XIX ed il XX secolo, nel XXI secolo sono le connessioni, le tecnologie ed i dati a svolgere questo importante ruolo.

I dati, hanno non solo permesso e promosso il progresso sociale, ma creato nuove opportunità di business, modificato completamente interi settori industriali e sviluppato nuove figure professionali.

Viviamo un'epoca storica che molti chiamano Data Economy: tutto ruota attorno alla capacità delle istituzioni e delle imprese di usufruire al massimo dei dati a disposizione, con l'obiettivo principale di migliorare la loro performance e la qualità dei servizi.

Qual è il valore dei tuoi dati personali?

FINANCIAL TIMES

Media

How much is your personal data worth?

Use our calculator to check how much multibillion-dollar data broker industry might pay for your personal data

JUNE 12 2013 by [Emily Steel](#), [Callum Locke](#), [Emily Cadman](#) and [Ben Freese](#)

Explore how valuable your data are with this interactive calculator.

While the [multibillion-dollar data broker industry profits](#) from the trade of thousands of details about individuals, those bits of information are often sold for a fraction of a penny apiece, according to industry pricing data viewed by the Financial Times.

The average person's data [often retails for less than a dollar](#).

General information about a person, such as their age, gender and location is worth a mere \$0.0005 per person, or \$0.50 per 1,000 people. A person who is shopping for a car, a financial product or a vacation is slightly more [valuable to companies eager to pitch those goods](#).

Certain milestones in a person's life prompt major changes in buying patterns,



- Se i dati sono il petrolio del nostro millennio anche i nostri dati devono avere un valore.
- Ebbene sì, il Financial Times, per sensibilizzare i cittadini su questo tema, ha sviluppato un sito che ci permette di inserire i nostri dati ed alla fine ci dice quanto valgono.
- <http://ig.ft.com/how-much-is-your-personal-data-worth/>
- I vostri dati valgono tantissimo.....

E se di questi dati ne avessimo tantissimi?

Il GDPR rappresenta un approccio difensivo alla gestione dei dati. Protegge il proprietario dei dati o previene conseguenze per chi utilizza i dati?

I braccialetti brevettati da Amazon

- Il device brevettato, ma non ancora utilizzato (2018), ha l'obiettivo di “aiutare” i dipendenti a rintracciare velocemente la merce in magazzino.
- Facilitare il lavoro dei magazzinieri nel rintracciare le merci. Sarebbe questa, stando al documento di deposito brevetti, l'obiettivo del braccialetto elettronico che Amazon ha realizzato per monitorare i suoi lavoratori.
- I device dovranno essere indossati ai polsi e guideranno il lavoratore alla ricerca degli oggetti nei magazzini



Il trattamento

- Qualsiasi operazione o insieme di operazioni, compiute con o senza l'ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali, come la raccolta, la registrazione, l'organizzazione, la strutturazione, la conservazione, l'adattamento o la modifica, l'estrazione, la consultazione, l'uso, la comunicazione mediante trasmissione, diffusione o qualsiasi altra forma di messa a disposizione, il raffronto o l'interconnessione, la limitazione, la cancellazione o la distruzione;
- Il registro dei trattamenti
- La classificazione dei trattamenti

Titolare del trattamento (data controller)

- La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che, singolarmente o insieme ad altri, determina le finalità e i mezzi del trattamento di dati personali; quando le finalità e i mezzi di tale trattamento sono determinati dal diritto dell'Unione o degli Stati membri, il titolare del trattamento o i criteri specifici applicabili alla sua designazione possono essere stabiliti dal diritto dell'Unione o degli Stati membri;
- Il titolare del trattamento, nel caso di pubblica amministrazione, è sempre una persona giuridica.

Scopo di questa breve disamina non è chiarire la configurabilità o meno del responsabile interno nel riformato quadro europeo; vi è chi sostiene che tale ruolo sia incompatibile con il Regolamento generale sulla protezione dei dati e chi, invece, sostiene che la sopravvivenza del responsabile interno sia auspicabile. Le due opposte fazioni vedono schierati commentatori di indubbia autorevolezza e qualunque sia la scelta definitiva che verrà compiuta dal legislatore nazionale probabilmente non sederà il dibattito.

Responsabile del trattamento (Data processor)

- Il responsabile del trattamento è una società esterna che ha un contratto con il titolare del trattamento.
- Il responsabile del trattamento (nel nuovo regolamento europeo data processor) è la persona fisica, giuridica, pubblica amministrazione o ente che elabora i dati personali per conto del titolare del trattamento (art. 4, par. 1, n. 8).
- Il responsabile del trattamento è definito dal Regolamento europeo come “la persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che tratta dati personali per conto del titolare del trattamento.
- L'articolo 28 del Regolamento generale sulla protezione dei dati prevede altresì che “qualora un trattamento debba essere effettuato per conto del titolare del trattamento, quest'ultimo ricorra unicamente a responsabili del trattamento che presentino garanzie sufficienti per mettere in atto misure tecniche e organizzative adeguate, in modo tale che il trattamento soddisfi i requisiti del presente regolamento e garantisca la tutela dei diritti dell'interessato”.

DPO(responsabile della protezione dei dati)

- Essendoci un così stretto legame tra il “core business” e l’attività di trattamento, anche quest’ultima viene fatta rientrare nell’alveo delle attività principali e, di conseguenza, ogni organizzazione dovrà designare un DPO. Un simile ragionamento si può fare con una società di vigilanza privata: l’attività di sorveglianza è indissolubilmente legata all’attività di trattamento dei dati personali relativi e, quindi, l’attività principale comprenderà non solo la prima attività, ma anche la seconda.
- Diversamente, sebbene tutte le imprese trattino necessariamente dei dati personali (ad esempio per i pagamenti dei dipendenti...), tuttavia non ricade su di esse l’obbligo di nominare il DPO: le citate attività di trattamento dati, per quanto indispensabili ed essenziali, sono considerate “ancillary” e quindi di supporto al “core business”.

DPO(responsabile della protezione dei dati)

Il DPO è obbligatorio in qualsiasi caso in cui il trattamento sia effettuato:

- da una pubblica amministrazione o da un suo organismo,
- da società con più di 250 dipendenti,
- da aziende, le cui attività principali siano costituite, per loro natura, scopo o finalità, da sistematico e regolare monitoraggio delle persone interessate, oppure se l'attività principale del titolare implicherà un trattamento su larga scala di dati sensibili, relativi alla salute o alla vita sessuale, genetici, oppure giudiziari e biometrici. (escluse comunque le autorità giurisdizionali)

I compiti del DPO

- Informare il titolare e gli incaricati, circa gli obblighi derivanti dai dati trattati;
- Monitorare l'implementazione ed applicazione delle politiche adottate dal titolare in materia di protezione dei dati, assegnazione delle responsabilità, formazione delle risorse umane (in materia di protezione dei dati) ed in materia di verifiche derivanti da quanto sopra;
- Verificare la redazione della documentazione prevista. Vengono riconosciuti importanti principi come l'accountability, ovvero un obbligo del rendiconto delle attività che incidono sulla protezione dei dati personali;
- Monitorare che accessi illeciti ai dati siano notificati
- Monitorare l'efficacia, l'adeguatezza e l'applicazione del DPIA (Data Protection Impact Assessment) nonché la sistematica autorizzazione e consultazione del titolare al trattamento verso il DPO prima di adottare una decisione che coinvolga il trattamento dati e la privacy
- Rispondere e cooperare con le richieste dell'autorità Garante per la Privacy;
- Agire come punto di contatto per le questioni, sollevate dal Garante, correlate ai trattamenti svolti in azienda.

Tracciare gli accessi

- Molti clienti in vista dell'entrata in vigore del GDPR chiedono che il prodotto consenta di tracciare tutte le operazioni/audit svolte dagli incaricati/utenti (non solo amministratori di sistema), producendo e conservando adeguati log.

Tale richiesta è legittima? O dipende dalla natura del dato?

- Risposta - Il tracciamento degli accessi ai sistemi o delle operazioni effettuate dagli incaricati o utenti è da sempre considerato una preventiva ed idonea misura di sicurezza al fine di prevenire il rischio di accessi non autorizzati o trattamenti non consentiti (ad es., oltre che per gli amministratori di sistema, il tracciamento è già previsto per diversi sistemi utilizzati nel settore delle comunicazioni elettroniche, in ambito sanitario, nelle banche, ecc.).

Alla luce dei principi di accountability e risk-based approach di cui al GDPR, è chiaro quindi che tale misura può quindi risultare sicuramente adeguata in base alla rischiosità del trattamento dei dati personali che si intende presidiare e particolarmente utile anche nell'ottica di monitorare eventuali data breach.

Ma, rispetto alla richiesta di implementazione di tale misura, è comunque necessario contemperare l'esigenza di sicurezza dei trattamenti di dati personali con i limiti in materia di controlli a distanza dei lavoratori previsti dallo statuto dei lavoratori, che richiamano anche i principi della normativa privacy. Per cui, è da escludere a priori la possibilità di un tracciamento generalizzato in relazione a mere esigenze di protezione dati ed occorre ogni volta verificare quale sia l'ambito e livello del possibile tracciamento in relazione alle finalità perseguite dal cliente, i tempi di conservazione dei log, modalità di controllo, soggetti che possono accedervi, adempimenti nei confronti dei dipendenti/utenti interessati, ecc. (ASSOSOFTWARE - Data Protection Working Group – FAQ)

I file con i tracciamenti (file di log)

- Cosa tracciare di un trattamento
- Con quali strumenti tracciarli
- Come conservare la tracciatura di un trattamento
- Come interrogare la tracciatura di un trattamento

LAVORO

Licenziato per accesso abusivo a email di colleghi: qual è il valore dei log?

Tribunale, Napoli, sez. lavoro, ordinanza 29/04/2014

Aggiornato il 11/07/2014

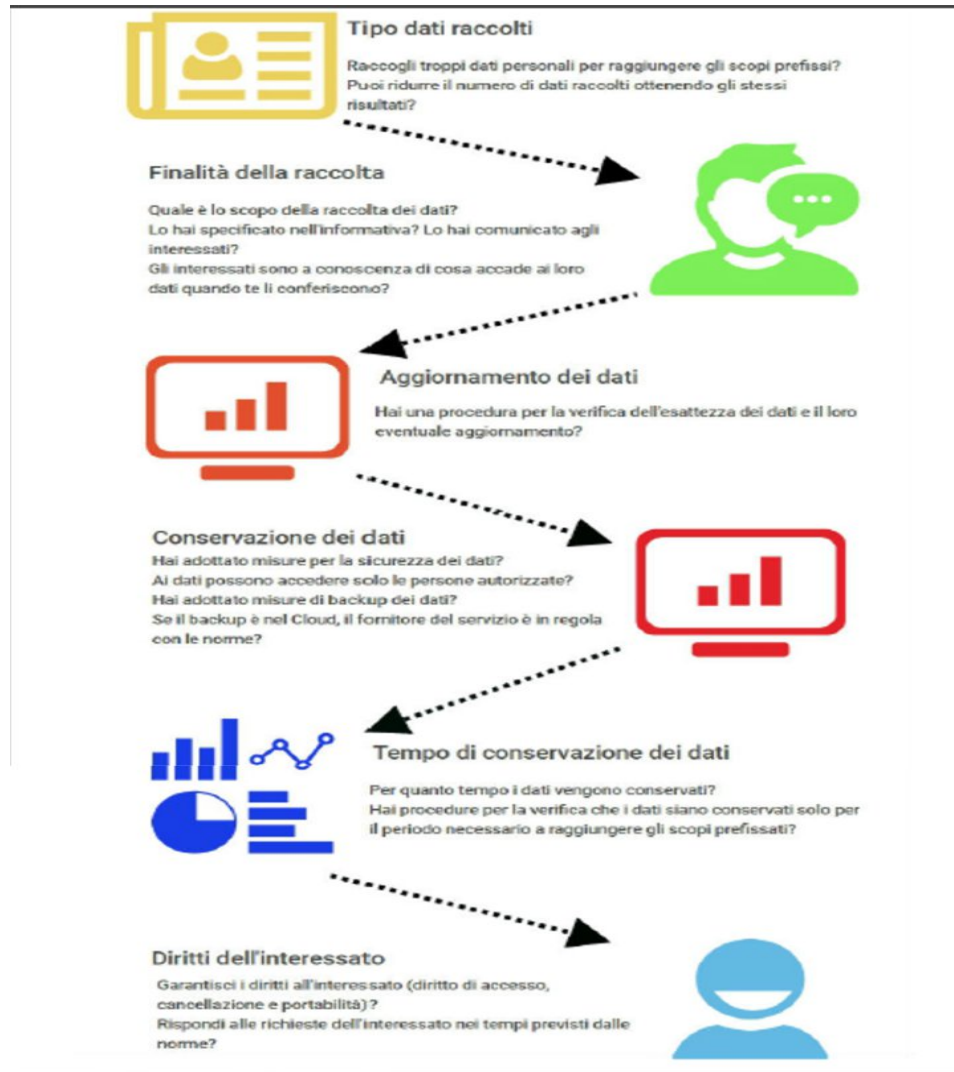
I dati

- Dati raccolti con il consenso del soggetto interessato e trattati dal titolare del trattamento.
- Dati acquisiti in chiaro e conservati nelle base dati aziendali.
- Come gestire questi dati? In quale forma? Come renderli fruibili a terzi?
- Una soluzione utile a questi quesiti può arrivare dalle tecniche di anonimizzazione.

Data protection vs Data privacy

- Data Protection
 - the process of safeguarding important information from corruption, compromise, or loss. This process includes backup and recovery as well as controls around data security and data integrity.
- Data Privacy (a.k.a. information privacy)
 - the process of managing certain types of data such as Personal Identifiable Information (PII) and Protected Health Information (PHI) to ensure that it is not misused.
- To simplify even more, while data protection provides tools and policies to safeguard data, data privacy restricts access to sensitive data.

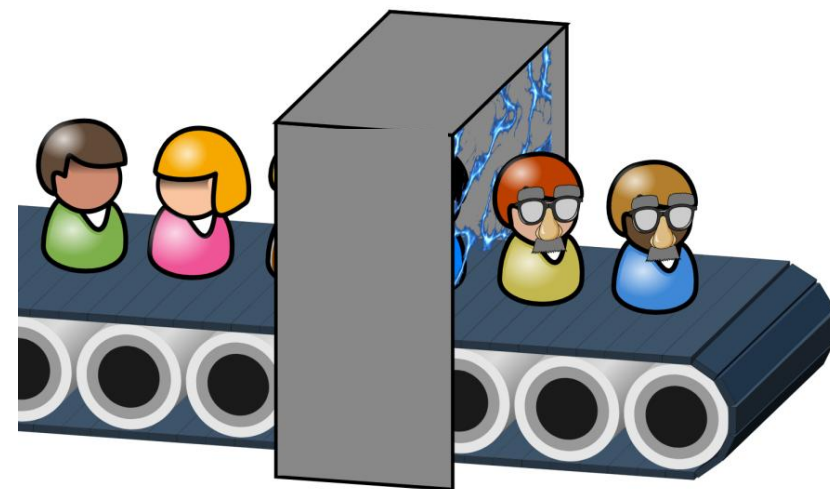
GDPR: il ciclo di vita del dato personale



- Tipo di dati raccolti
- Finalità della raccolta
- Aggiornamento dei dati
- Conservazione dei dati
- Tempo di conservazione dei dati
- Diritti dell'interessato

Anonimizzazione

- La direttiva 95/46/CE e gli altri strumenti giuridici rilevanti dell'UE, parlano di anonimizzazione come risultato del trattamento di dati personali volto a impedire irreversibilmente l'identificazione del soggetto trattato.
- L'anonimizzazione costituisce quindi un trattamento successivo dei dati personali; in quanto tale, deve soddisfare il requisito di compatibilità tenendo conto delle motivazioni giuridiche e delle circostanze del trattamento successivo.
- Questo è vero in particolare per i dati sulla salute (health data). Per esempio nel record di un paziente noi eliminiamo nome e cognome e lo sovrascriviamo con un codice random. Ma tale record ha associata una malattia. Se questa è una malattia rara può aiutare ad individuare il paziente
- Quindi l'anonimizzazione corrisponde alla trasformazione di un dati in modo che sia impossibile risalire al proprietario dello stesso
- Analogamente la pseudonimizzazione è una trasformazione del dato che rende complesso risalire al dato originale o al suo titolare



Anonimizzazione

- Esaminando alcuni studi sui processi di anonimizzazione e analizzando alcune pubblicazioni di ricerca emerge chiaramente che non è semplice ottenere un insieme di dati effettivamente anonimo a partire da un ampio insieme di dati personali, mantenendo al contempo tutte le informazioni sottostanti necessarie per espletare l'attività di analisi richiesta.
- Ad esempio, un insieme di dati considerato anonimo potrebbe essere combinato con un altro insieme di dati in maniera tale da consentire l'identificazione di uno o più soggetti.



in a virtual event,
live on October 13th, 2020



Support The Guardian

Available for everyone, funded by readers

Contribute →

Subscribe →

Search jobs

Sign in

Search ▾

International
edition ▾

The Guardian

News

Opinion

Sport

Culture

Lifestyle

More ▾

Coronavirus World UK Environment Science Global development Football **Tech** Business Obituaries

Data and computer security

🕒 This article is more than 3 years old

'Anonymous' browsing data can be easily exposed, researchers reveal

A journalist and a data scientist secured data from three million users easily by creating a fake marketing company, and were able to de-anonymise many users



Advertisement

BRICOMAN

PIÙ PROFESSIONALE, MENO CARO

LE MIGLIORI
MARCHE
A PREZZI
DA INGROSSO

in

SECURITYWEEK
CYBERSECURITY NEWS, INSIGHTS & ANALYSIS

Malware & Threats ▾ Security Operations ▾ Security Architecture ▾ Risk Management ▾ CISO Strategy ▾ ICS/OT ▾ Funding/M&A ▾

The First Comprehensive
Research Report For The
Identity Attack Surface



SILVERFORT

Learn More

PRIVACY

New Deanonymization Attack Works on Major Browsers, Websites

Researchers with the New Jersey Institute of Technology have devised a new targeted deanonymization attack that relies on a cache side-channel and which they say is efficient on multiple architectures, operating systems, and browser versions, and works on major websites.



By [Ionut Arghire](#)
July 18, 2022



Alcuni esempi

1. Ho interrogato il DB della mia università per conoscere fascia di reddito e numero famiglie. È un dato aggregato, che sembrerebbe non porre problemi di privacy.
 - Dalla segreteria osservo che oggi si è iscritto solo uno studente. Confrontando il risultato della query di ieri e quello della query oggi, riesco a conoscere la fascia di reddito della sua famiglia.
2. Un dato temporale: un'azienda registra gli accessi ad internet dei suoi dipendenti: (nome, ip, data e ora, sito visitato). Se cancello il nome, ma mantengo data e ora un altro dipendente può arrivare a sapere il sito visitato e chi l'ha visitato (perché a quell'ora pochi erano presenti)
3. “anyone who visits their own analytics page on Twitter ends up with a URL in their browsing record which contains their Twitter username, and is only visible to them. Find that URL, and you’ve linked the anonymous data to an actual person. A similar trick works for German social networking site Xing” (The Guardian:
<https://www.theguardian.com/technology/2017/aug/01/data-browsing-habits->

La complessità dei problemi

1. In una comunità vivono in totale 41 tra uomini e donne e la loro età media è di 38 anni
2. Tra di loro ci sono 20 uomini con età media pari a 30 anni
3. Ci sono inoltre 22 "ricchi" con età media di 45 anni
4. C'è modo di estrarre un dato puntuale?

1. Essendo in totale 41 persone, e considerato che 20 (maschi)+22(ricchi) fa 41, allora c'è almeno un uomo che è anche ricco, Quest'uomo è presente in tutte e due le medie.
2. Quindi possiamo dire, se M è l'età di questo uomo
 - $20 \cdot 30 - M + 22 \cdot 45 - M$ (tolgo l'uomo dalle due medie) = $1590 - 2M$
3. Aggiungo una sola volta M (in modo da tornare a 41) e quindi
 - $1590 - 2M + M = 41 \cdot 38$
 - $M = 1590 - 41 \cdot 38 = 32$

C'è un uomo che è anche ricco e ha 32 anni!!

Alcuni esempi

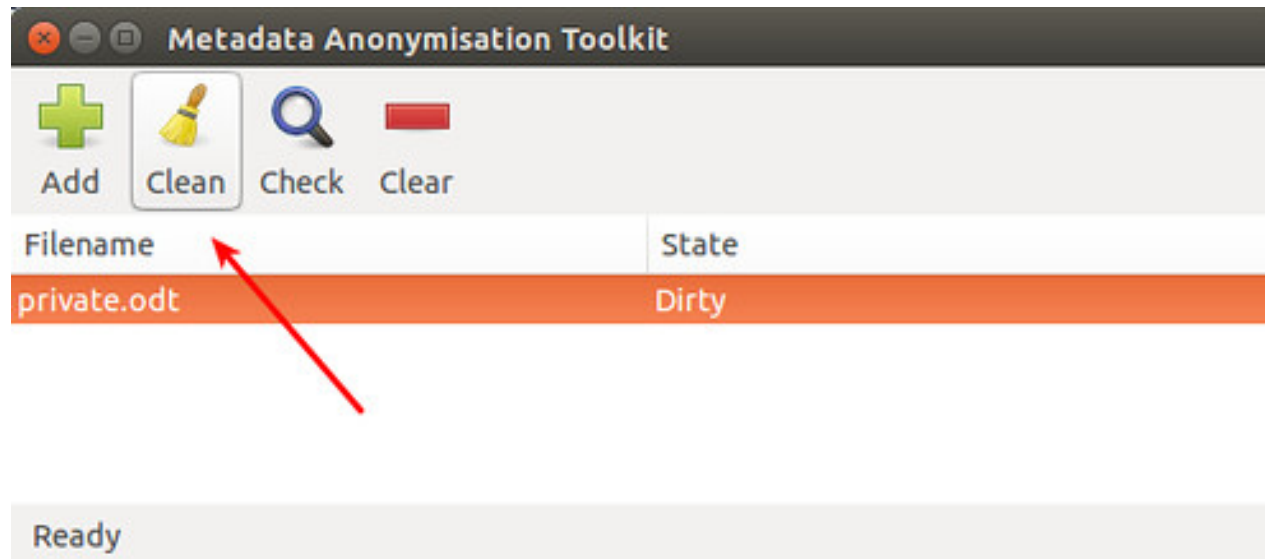
4. Per altri utenti, un approccio più probabilistico può deanonimizzarli.
5. Per esempio, possono bastare 10 URL per identificare in modo univoco una persona
 - basti pensare a quante persone ci sono nella vostra azienda, nella vostra banca, nel vostro hobby, nel vostro giornale preferito e nel vostro gestore di telefonia mobile.
6. Creando "impronte digitali" dai dati, è possibile confrontarli con altre fonti più pubbliche di URL visitati, come gli account dei social media o le playlist pubbliche di YouTube.

Anonimizzazione: il GDPR

- Per rendere anonimi determinati dati, gli stessi devono essere privati di elementi sufficienti per impedire l'identificazione del soggetto interessato.
- I dati devono essere trattati in maniera tale da non poter più essere utilizzati per identificare una persona fisica utilizzando “l'insieme dei mezzi che possono essere ragionevolmente utilizzati” dal responsabile del trattamento o da altri.
- Caratteristica importante è che il trattamento deve essere irreversibile.
- La normativa non specifica come si debba o si possa effettuare il processo di anonimizzazione.
- Importa il risultato: i dati devono essere tali da non consentire l'identificazione della persona interessata mediante “l'insieme” dei mezzi che “possono” essere “ragionevolmente” utilizzati.

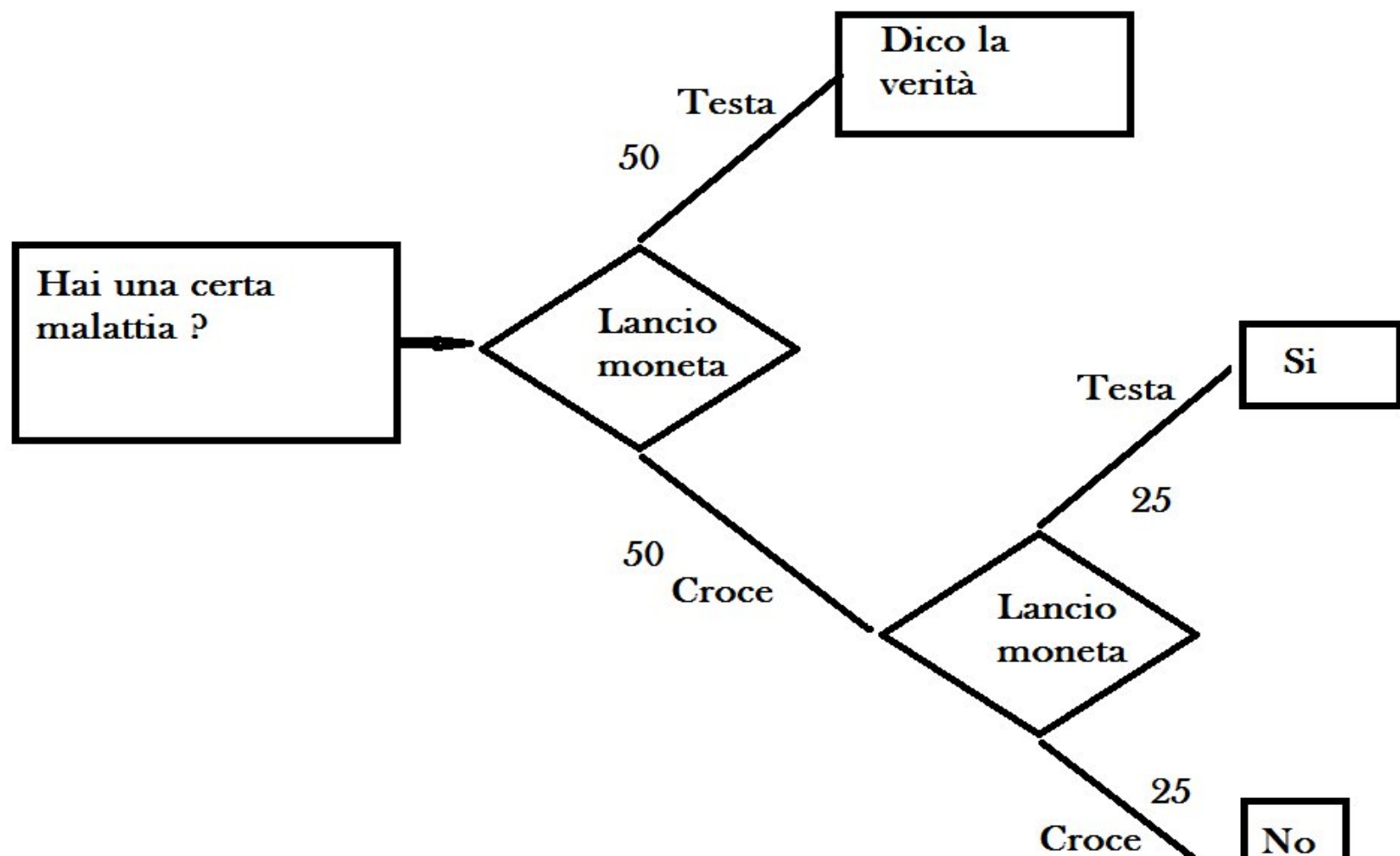
Tecniche di anonimizzazione

- Randomizzazione
- Generalizzazione (raggruppamento in classi)

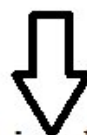


Privacy differenziale

- Immaginiamo di voler creare un sample di dati sulla diffusione di una malattia in una certa città. Gli intervistati (anonimi), prima di rispondere lanciano una moneta:
 - se esce testa rispondono sinceramente, se esce croce lanciano nuovamente la moneta:
 - se esce testa risponderanno sì,
 - se esce croce risponderanno no.
- La certezza della privacy è garantita dalla negabilità di ogni risultato: c'è sempre una probabilità del 25% che la risposta non sia vera.
- Allo stesso tempo il meccanismo permette di stimare le persone malate partendo dal numero di risposte positive randomizzate: infatti il numero di "sì" attesi è $1/4$ per le risposte negative più $3/4$ per le risposte affermative.



	Si
	75%
1000	400 si
	600 no



Con dei calcoli
io posso arrivare
a salvare
l'informazione
cioè sapere
esattamente
quanti hanno la
malattia e quanti
no

Privacy by default, privacy by design

- Privacy by default

- Il principio di privacy by default (protezione per impostazione predefinita) prevede, appunto, che per impostazione predefinita le imprese dovrebbero trattare solo i dati personali nella misura necessaria e sufficiente per le finalità previste e per il periodo strettamente necessario a tali fini. Occorre, quindi, progettare il sistema di trattamento di dati garantendo la non eccessività dei dati raccolti. in modo che l'interessato riceva un alto livello di protezione anche se non si attiva per limitare la raccolta dei dati
- Il principio in questione ovviamente tocca tutti gli aspetti del trattamento, non solo la quantità e qualità dei dati, ma anche il periodo di trattamento e le persone che possono accedere ai dati.

Privacy by default, privacy by design

- Privacy by design

- prevenire non correggere, cioè i problemi vanno valutati nella fase di progettazione, e l'applicativo deve prevenire il verificarsi dei rischi;
- privacy come impostazione di default (ad esempio, non deve essere obbligatorio compilare un campo di un form il cui conferimento di dati è facoltativo);
- privacy incorporata nel progetto (ad esempio, l'utilizzo di tecniche di pseudonimizzazione o minimizzazione dei dati);
- massima funzionalità, in maniera da rispettare tutte le esigenze (rifiutando le false dicotomie quali più privacy = meno sicurezza);
- sicurezza durante tutto il ciclo del prodotto o servizio, le misure devono essere commisurate al rischio;
- visibilità e trasparenza del trattamento, cioè tutte le fasi operative devono essere trasparenti in modo che sia verificabile la tutela dei dati;
- centralità dell'utente, quindi rispetto dei diritti, tempestive e chiare risposte alle sue richieste di accesso.

La violazione dei dati (data breach)

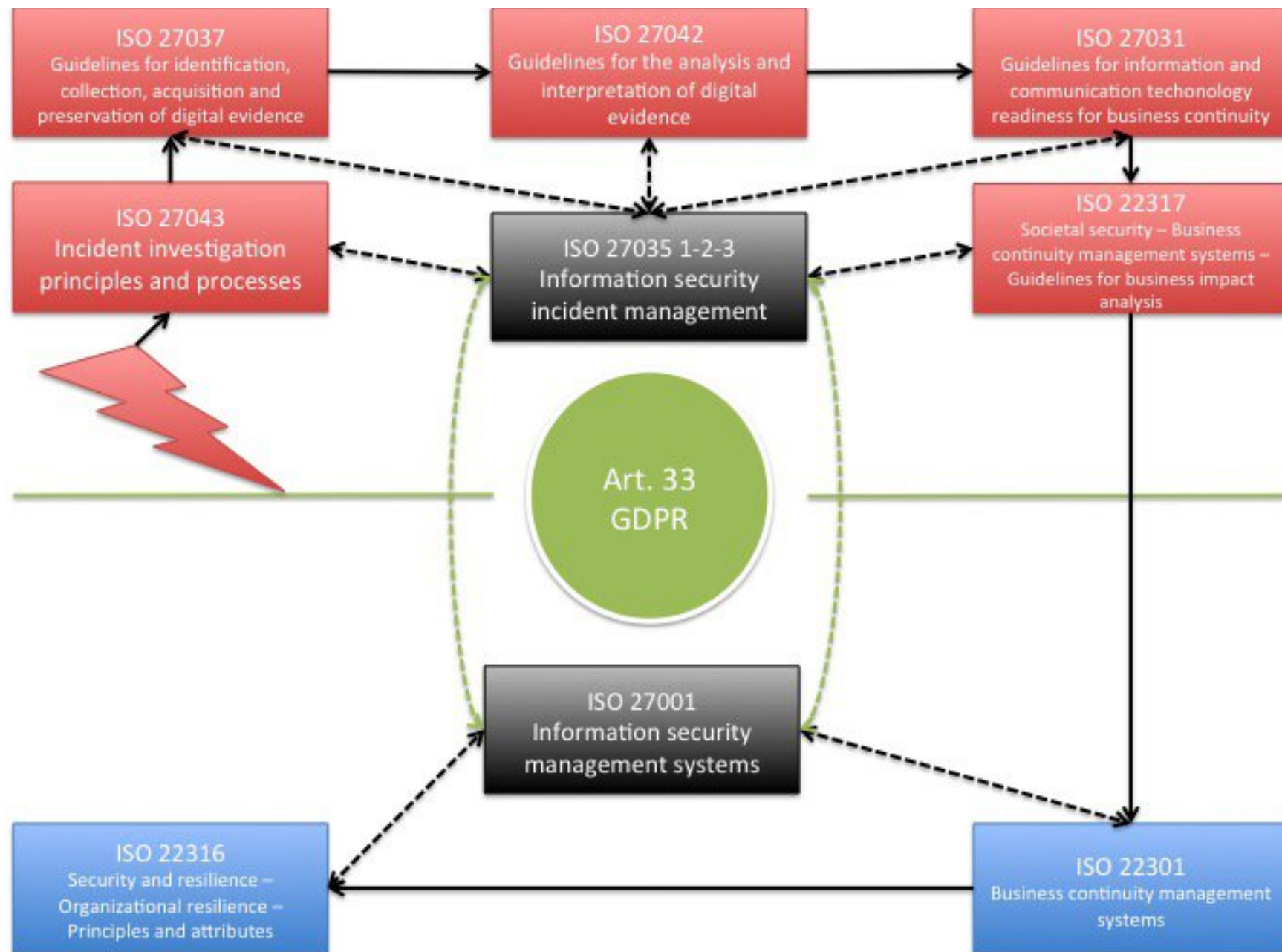
- Per “Violazione di dati” si intende la violazione di sicurezza che comporta accidentalmente o in modo illecito la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l’accesso ai dati personali trasmessi, conservati o comunque trattati (Art. 4 p.12 GDPR).
- L’art. 33 del Regolamento Europeo 679/2016 (GDPR) impone al titolare del trattamento di notificare all’autorità di controllo la violazione di dati personali (data breach) entro settantadue ore dal momento in cui ne viene a conoscenza.

La violazione dei dati (data breach)

- L'obbligo di notifica scatta se la violazione, ragionevolmente, comporta un rischio per i diritti e le libertà delle persone fisiche, qualora, poi, il rischio fosse elevato, allora, oltre alla notifica, **il titolare è tenuto a darne comunicazione all'interessato.**
- L'eventuale ritardo nella notificazione deve essere giustificato, il mancato rispetto dell'obbligo di notifica, invece, pone l'autorità di controllo nella condizione di applicare le misure correttive a sua disposizione.
- Occorre in ogni caso tenere conto che, la mancata notifica e/o comunicazione, possono rappresentare per l'autorità di controllo un indizio di carenze più profonde e strutturali quali ad esempio carenze o inadeguatezza di misure di sicurezza.

La violazione dei dati (data breach)

- Si possono distinguere tre tipi di violazioni:
 1. Violazione di riservatezza, ovvero quando si verifica una divulgazione o un accesso a dati personali non autorizzato o accidentale.
 2. Violazione di integrità, ovvero quando si verifica un'alterazione di dati personali non autorizzata o accidentale.
 3. Violazione di disponibilità, ovvero quando si verifica perdita, inaccessibilità, o distruzione, accidentale o non autorizzata, di dati personali.



Identity Access Management and GDPR

- Il General Data Protection Regulation (GDPR) mira a regolare il modo in cui le Organizzazioni raccolgono e memorizzano le informazioni sui loro clienti.
- Con questo nuovo Regolamento le Organizzazioni sono chiamate ad essere più trasparenti sulle procedure con le quali i dati personali dei loro clienti sono raccolti, memorizzati ed usati.
- In questa prospettiva IAM assume una importanza massima. Uno IAM assicura che solo chi è autenticato e poi autorizzato accede ai dati personali di un cliente oppure di un impiegato dell'Azienda. In questo senso un'Organizzazione si deve dotare di uno IAM efficace.

IAM for GDPR compliance

- Segregation of duty: lo IAM deve prevedere che più di un utente devono agire per completare il trattamento del dato di un singolo cliente.
- Session monitoring: monitora le sessioni utente quando le stesse accedono ai dati dei clienti, permettendo la tracciatura di un data breach
- Minimizzazione dei privilegi: ogni utente accede solo ai dati ed alle operazioni sugli stessi, strettamente necessari per compiere il suo ruolo nell'ambito di un task.
- Access recertification: riverificare periodicamente le sessioni rispetto agli utenti per evitare operazioni di hijacking. Rimuovere le sessioni scadute, terminate o non più usate.
- Privileged account management: gestire attentamente gli amministratori e tutti coloro che hanno account privilegiati.
- Authentication: curare la fase di autenticazione degli utenti, privilegiando tecniche di strong authentication ma anche incrementalità nell'autenticazione per rendere flessibili gli accessi.
- Personal data encryption
- Protezione da attacchi ransomware

Privacy Impact Assessment

Right to be forgotten

The right to be forgotten appears in Recitals 65 and 66 and in Article 17 of the GDPR.

It states, “The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay and the controller shall have the obligation to erase personal data without undue delay” if one of a number of conditions applies.

“Undue delay” (ritardo indebito) is considered to be about a month. You must also take reasonable steps to verify the person requesting erasure is actually the data subject.

Right to be forgotten

Il diritto all'oblio tuttavia non è qualcosa di automatico.

Il GDPR specifica una serie di situazioni in cui questo diritto esiste. Ma specifica anche una serie di situazioni in cui tale diritto non c'è.

Es. situazioni legate all'interesse sociale, medico del dato. Oppure a situazioni legali (contenziosi in corso).

Right to be forgotten

L'eliminazione dei dati deve essere effettiva

Dobbiamo eliminarli dai file di log, dai backup, dalle basi di dati e verificare che non ci siano copie dei dati o eliminazioni fittizie dei dati stessi (copie tecniche!!!!)

Right to be forgotten

In its December 5, 2018 ruling (DSB-D123.270/0009-DSB/2018, German), the DPA (National Data Protection Authority) made a decision based on the above anonymization question:

- is it sufficient for the disposal of PI(personal information) (and thus for the fulfillment of a data subject's right to erasure under Article 17 GDPR), for personal data to be anonymized instead of erased to meet the GDPR's (and CCPA) right to be forgotten provision?
- In this case, the DPA ruled that the anonymization of personal data can be used to meet the law's data deletion requirement.

Impatto del GDPR

- Il GDPR e i regolamenti ad esso collegati hanno impatti diversi a seconda dal profilo di un'organizzazione e dal modo in cui raccoglie ed elabora le e tratta le informazioni sulle
- individui
- Il GDPR ha un impatto sulle aree di:
 - Governance dei dati
 - Gestione della privacy
 - Gestione della sicurezza
 - Gestione del rischio
- I processi aziendali e i sistemi IT dovranno essere modificati e dovranno essere acquisiti nuovi processi e sistemi per supportare il successo del funzionamento del GDPR
- Il funzionamento degli accordi di outsourcing subirà l'impatto del GDPR



Impatto del GDPR



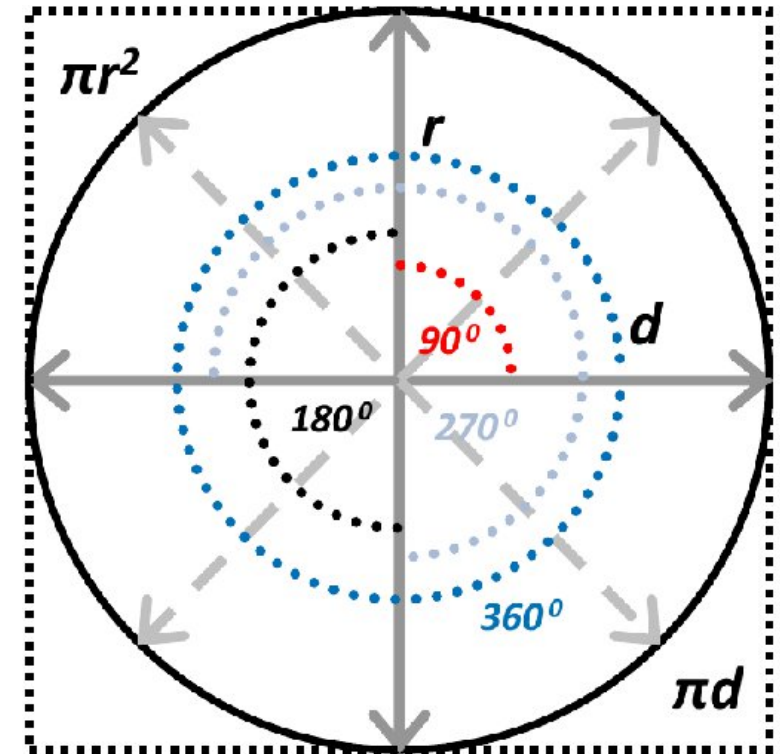
- Le organizzazioni dispongono di dati personali in molte posizioni utilizzate da diverse applicazioni che utilizzano diverse tecnologie di archiviazione
- Il GDPR richiede ora l'implementazione di un nuovo e più rigoroso regime dei dati
- Le organizzazioni devono considerare un approccio coerente tra tutte le piattaforme di dati personali

Non c'è una soluzione proposta

- Non esiste un'unica soluzione per raggiungere la conformità al GDPR che si applichi a tutte le organizzazioni e a tutti gli aspetti del GDPR.
- Le organizzazioni devono definire la loro strategia di conformità al GDPR e il loro approccio alla governance dei dati prima di considerare soluzioni a lungo termine

Riusare standard e tecnologie già esistenti

- Esistono metodologie esistenti, ben documentate, dettagliate, ben collaudate in aree come la governance dei dati, la privacy dei dati, la gestione della sicurezza delle informazioni, archiviazione digitale, governance dei fornitori e gestione delle relazioni di outsourcing che possono essere riutilizzare con successo per raggiungere la conformità al GDPR senza la necessità di cercare nuovi approcci
- La ruota non ha bisogno di essere reinventata.
- Utilizzate quindi framework e metodologie già collaudati e metodologie per migliorare sistematicamente le capacità, l'esperienza e la pratica in aree di competenza chiave
- Il mondo non ha bisogno di nuovi framework e metodologie. Ha bisogno di quelle già esistenti se



Riusare standard e tecnologie già esistenti

ISO 15489 Records Management

ISO 16175 Standard for Digital Filing

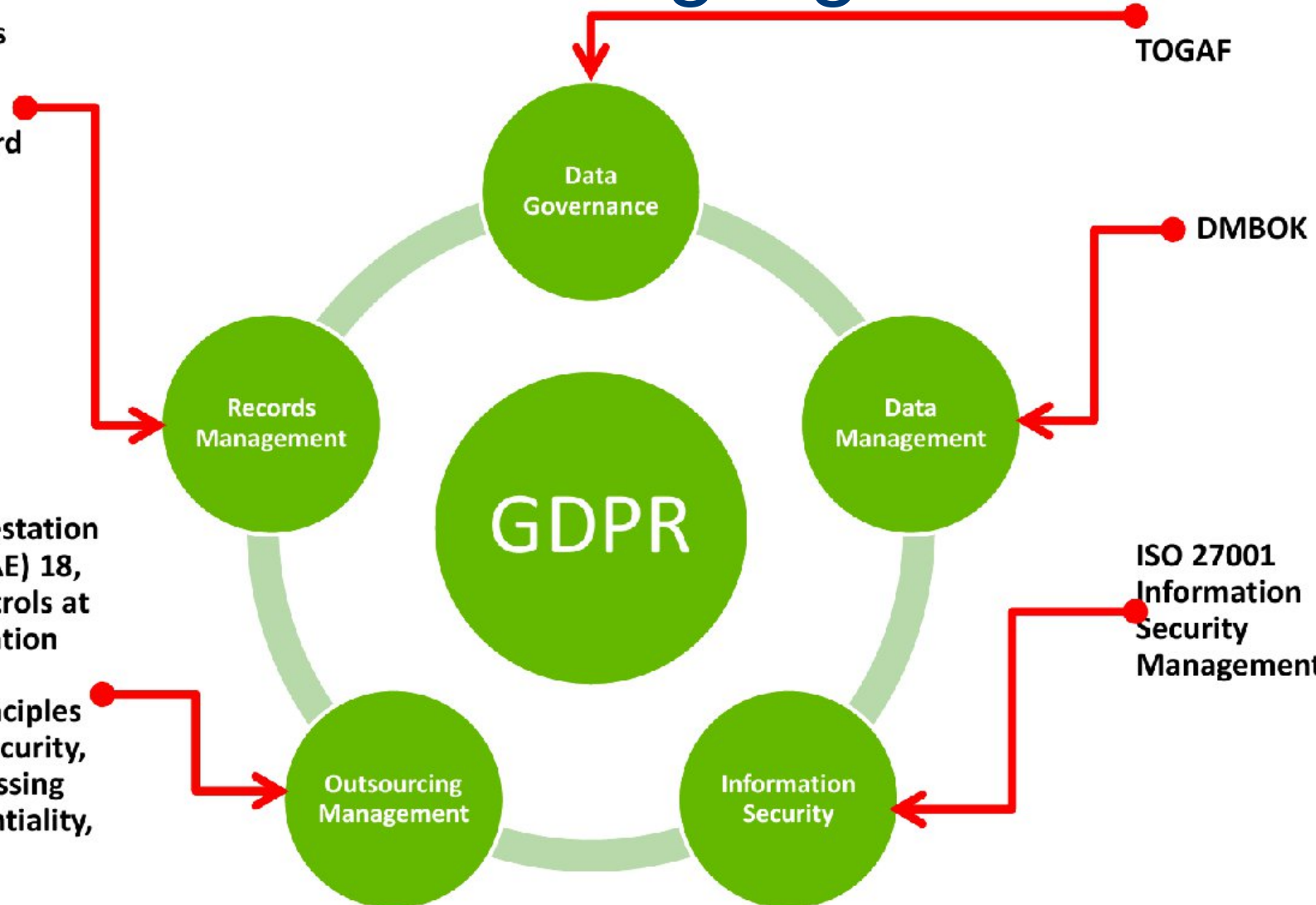
Standards for Attestation Engagements (SSAE) 18, Reporting on Controls at a Service Organisation

Trust Services Principles and Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy

TOGAF

DMBOK

ISO 27001 Information Security Management



No Silver Bullet



- There is not silver bullet to achieve GDPR compliance
- Just a bunch of regular bullets to fire at the problem



Directive on Security of Network and Information Systems (NIS Directive)

- Aim of the NIS Directive is to ensure there is a common and high-level of EU-wide information systems and network security and cyber security by:
 - Improving national information and network security capacity and effectiveness including having Computer Security Incident Response Teams (CSIRTs) or Computer Emergency Response Teams (CERTs)
 - Increasing co-operation on information and network security across all Member States
 - Introducing binding security obligations and incident reporting obligations for operators of essential services (OESs) in critical national infrastructure (CNI)
 - Member States will be responsible for dealing with the security of services provided by multinational companies across the European Union that have their European headquarters located in that country



NIS Security Principles

- Use these security principles to create an operational security framework to reduce the chances of a data breach

Personal Information

- Personal information is at the core of GDPR
- Personal data is defined in Article 4(1) of the GDPR:
 - ‘Personal data’ means any information relating to an identified or identifiable natural person (‘data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person

Personal Information

- Information is personal if it is:
 - Owned by a person
 - About a person
 - Directed towards a person
 - Sent or posted or communicated by a person
 - Experienced by a person
 - Relevant to a person

Personal Information

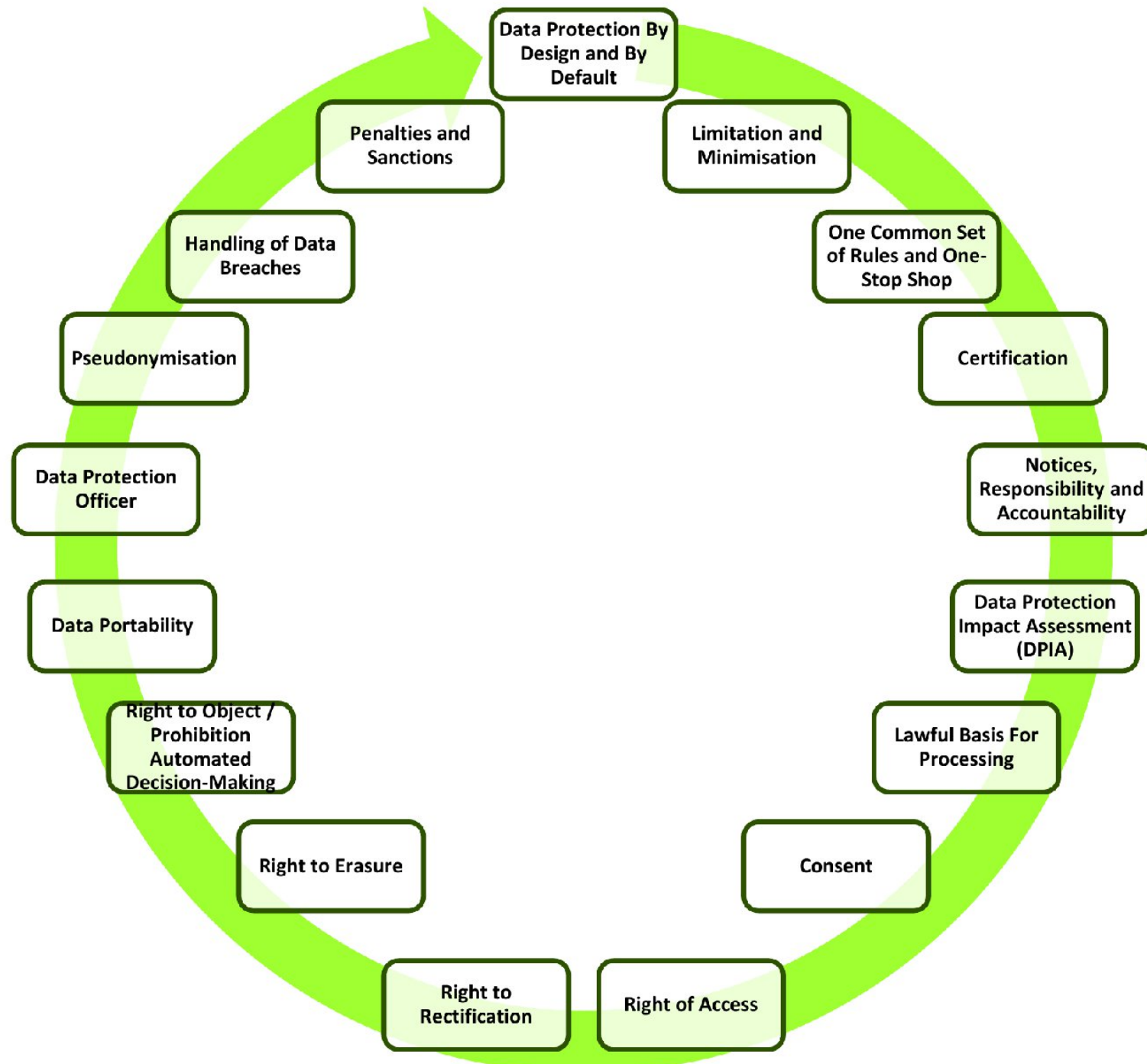
- The definition of personal data is very important
 - It does not just include information a person explicitly supplies
 - It includes implicit information such as browsing history
- GDPR identifies special categories of personal data for which processing is subject to additional constraints
 - Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation shall be prohibited

Personal Data Type	Personal Data Items
Personal Information	Name, such as full name, maiden name, mother’s maiden name, or alias
	Date of birth
	Place of birth
	Full home address
	Country, state, postcode or city of residence
	Marital status
	Telephone numbers, including mobile, business and personal numbers
	Information identifying personally owned property, such as vehicle registration number
	Passport number
	Social insurance or national insurance number
	Residence and geographic records
	Sexual orientation
Biographical Data	Specific age
	Height
	Weight
	Eye colour
	Hair colour
	Photographic image
	Gender
	Racial or ethnic origin
	Any defining physical characteristics
Digital Footprint	Digital identities, such as avatars and usernames/handles
	Logon details such as name, screen name, nickname, or handle
	Email address (if private from an association/club membership, etc.)
	IP addresses (in the EU)
	Geo-tracking information and location-based data
	Web usage behaviour or user preferences using persistent cookies
	Asset information, such as Internet Protocol (IP) or Media Access Control (MAC) address
	(MAC) address or other host-specific persistent static identifier that consistently
	Any information that links a particular person to a small, well-defined group
Medical or Heath Data	Patient identifier
	Number of sick days taken from employer and other information relating to any sick leave
	Visits to doctors
	Medical data
	Biological traits including DNA
	Fitness data
	Medical images such as X-rays, CT scans and ultra sound
	Biometric data such as fingerprints, retinal scans, voice signature or facial geometry
	Medication

Principles of GDPR

- Core of the GDPR are stated principles governing data processing, which are supported by detailed provisions
 - Lawfulness, Fairness and Transparency: Article 5(1)(a) sets out the principle that personal data shall be processed lawfully, fairly and in a transparent manner in relation to the data subject
 - Specified, Explicit and Legitimate Purpose: Personal data must only be collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; Article 5(1)(b)
 - Adequate, Relevant and Limited: Personal data shall be adequate, relevant and limited to what is necessary in relation to the purposes for which the data is processed; Article 5(1)(c)
 - Accurate and Up-To-Date: Personal data shall be accurate, and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that is inaccurate, having regard to the purposes for which it is processed, is erased or rectified without undue delay; Article 5(1)(d)
 - Pseudonymisation/Storage Limits: Personal data shall be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data is processed; Article 5(1)(e)
 - Security: Personal data shall be processed in a manner that ensures appropriate security of personal data, including protection against unauthorised or unauthorised processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures; Article 5(1)(f)

GDPR Implementation And Operational Principles



Data Protection By Design and By Default

- Article 25 of the GDPR requires that data protection is designed into the development of business processes for products and services
 - Appropriate measures to implement the data protection principles and to safeguard data must be put in place in an effective manner at the time the means of processing is determined and at the time of the processing itself
 - This is a mandatory requirement, breach of which can lead to a fine
- Article 25(2) addresses the concept of data minimisation and provides that the controller should implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed
 - Obligation applies to the amount of personal data collected, the extent of processing and the period of storage and accessibility
 - Data Protection by design and by default requires a combination of systems and processes
 - Changes to existing IT systems and possible new IT systems will be required to achieve this

Limitation and Minimisation

- The collection of personal data should be limited for specific and justifiable purposes
- The amount of personal data collected should be minimised
- The storage interval should be limited
- The type of processing should be limited and necessary
- There should be a legal basis for processing
- Access should be controlled and excluded by default rather than being inclusive
- Processing of special categories of personal data should be avoided unless absolutely required
- Data security should occur as a matter of course.
- Essentially, if there are any doubts and the data is not necessary, do not collect it

Certification??

- GDPR provides for a voluntary data protection certification regime to be established
- There is no certification approach or regime defined yet
- ENISA has documented a possible certification approach

Notices, Responsibility and Accountability

Mandatory Privacy Notice Contents	Specific Personal Information Collection Privacy Notice Contents
Identity and the contact details of the data controller	The length of time for which the personal data will be stored, or if that is not possible, the criteria used to determine it
Contact details of the data protection officer, if one exists – see below	The right to: • Request from the data controller access to • Request rectification or erasure of personal data • Restrict processing • Object to processing • Data portability
The purposes of the processing of personal data and the legal basis for this processing (Article 6 Lawfulness of Processing)	The right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal
Who receives the personal data	The right to complain to Supervisory Authority
Whether data is being transferred to a third country or international organisation and, if so, the safeguards that are being used and the means by which to obtain a copy of them or where they have been made available	If the provision of personal data is a statutory or contractual requirement or necessary to enter into a contract, as well as whether the person is obliged to provide the personal data and of the possible consequences of failure to provide the data
	The use of automated decision-making, including profiling and where this applies meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the person

Notices, Responsibility and Accountability

- The principle of Privacy By Design and By Default requires that data protection measures are designed and incorporated into the development of business processes and systems
- The data controller is responsible for implementing effective measures and being able to demonstrate the compliance of processing activities even if the processing is carried out by a separate data processor on behalf of the data controller
- Personal data should be pseudonymised as soon as possible after collection and expiry of its original use

Consent

- Explicit consent of the person must be obtained for data collection and processing, with Article 7 setting out the basic conditions required for a consent to be valid
 - The consent must be freely given
 - A proper explanation of what the individual is consenting to must have been provided before the consent is obtained
 - Separate consents must be given for separate purposes
 - Consent can be refused
 - Consent can be withdrawn at any time
- Consent should be informed
 - The identity of the controller and the processing purposes should be detailed
 - Silence or implied consent and pre-checked boxes on web pages are no longer valid
 - The organisation must ask for consent and obtain explicit consent
 - Plain language should be used and consent is unlikely to be achieved if data protection notices are unintelligible or over-complicated
 - Consent must be specific
 - Where the data processing has multiple purposes, consent should be given for all of them
 - The burden of proof that consent was obtained in a correct and explicit manner resides with the data controller
 - Consent management needs to include both the recording of consent and the circumstances under which it was provided and while there is no requirement that consent should be in writing, the evidential burden suggests that, in practical terms, this will occur

Right of Access

- Persons have the right to access their personal data and to get details about how this personal data is being processed
- The right of subject access is complemented by the right, under Article 20 of the GDPR, to data portability
- A controller is under an express obligation to facilitate the exercise by a data subject of their rights, including to subject access and data portability; Article 12(2).
- A controller's obligation under Article 20 (right of data portability) is to “transmit ... data to another controller without hindrance”
- Article 15(1) provides that a data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning them is being processed, and, where that is the case, access to the personal data and the information
- The data controller has to provide
 - Access to the data itself
 - The categories of personal data concerned
 - With whom the data is shared (that is to say, the recipients or categories of recipients to whom the personal data is or will be disclosed and in particular, recipients in third countries)
 - The envisaged storage period for the data or, if it is not possible to so specify, the criteria used to determine that period
 - How it acquired the data in the sense that where the personal data was not collected from the data subject, any available information as to the source of the personal data
 - The existence of the right of rectification or erasure or restriction of processing of personal data
 - The right to lodge a complaint with a supervisory authority
 - The existence of automated decision-making, including profiling, referred to in Article 22(1) and (4)

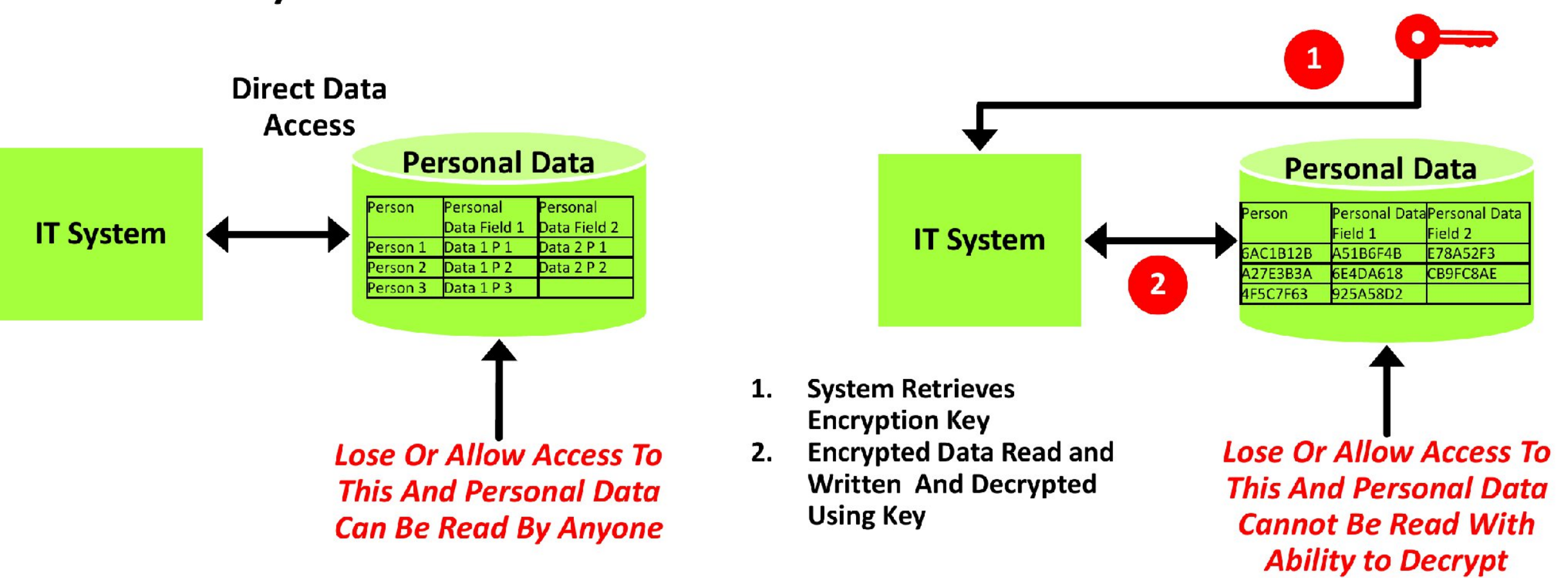
Data portability

- A person must be able to transfer their personal data from one controller to another without being prevented by the data controller - Article 20
 - This covers both the information content – what was supplied – and the metadata
- The right to data portability is the “right to receive the personal data concerning [the data subject], which [the data subject] has provided to a controller” – see Article 20(1)
- The right applies where consent to data processing has been provided under Article 6(1)(a) (express consent) or Article 9(2)(a) (special categories of personal data) and where the processing is automated
- The right does not apply where the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller – see Article 20(3)
- The right to data portability does not arise
 - Where data is processed by a controller under a legal duty or in exercise of discretionary powers
 - Where processing is necessary in order to protect the vital interests of the data subject or of another natural person
 - Processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller

Pseudonymization

- Pseudonymisation” is defined in Article 4(5) of the GDPR
- Means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person
- Article 29 Working Party:
 - “pseudonymisation is not a method of anonymisation. It merely reduces the linkability of a dataset with the original identity of a data subject, and is accordingly a useful security measure.”
- Encryption is a form of pseudonymisation
 - The original data cannot be read
 - The process cannot be reversed without the correct decryption key
 - GDPR requires that this additional information be kept separate from the pseudonymised data.
- Pseudonymisation reduces risks associated with data loss or unauthorised data access
 - Pseudonymised data is still regarded as personal data and so remains covered by the GDPR
 - It is viewed as part of the Data Protection By Design and By Default principle
- Pseudonymisation is not mandatory
 - Implementing pseudonymisation with existing IT systems and processes would be complex and expensive and, to that extent, pseudonymisation might be considered an example of unnecessary complexity within the GDPR

- Pseudonymisation is not anonymisation
 - Anonymisation means data cannot be attributed to a person
 - Pseudonymisation means data can be attributed to a person using additional information
 - Pseudonymisation just makes identifying persons from data more difficult, time-consuming and expensive



- Pseudonymisation means removing the link between data and its attribution to a specific individual
- Add a layer of complexity, time and expense to person identification
- There are many (complex) approaches to pseudonymisation
- Pseudonymisation aims to provide an extra layer of security
 - It does not stop personal data being lost
 - It just reduces the likelihood that lost personal data can be used

Penalties and Sanctions

- Failure to comply with GDPR can result in administrative penalties and other sanctions
- Warnings – under Article 58(2), a supervisory authority has specific powers to issue warnings to a controller or processing that intended processing operations are likely to infringe the GDPR and reprimands where processing operations have infringed the GDPR
- Data protection compliance audits – Article 58(1) confers on supervisory authorities investigative powers, including, at Article 58(1)(b) the power to carry out investigations in the form of data protection audits;
- Fines - two levels of fines
 - €10,000,000 or up to 2% of the annual worldwide turnover of the preceding financial year, whichever is the greater, for failures relating to:
 - Conditions applicable to child's consent in relation to information society services
 - Failures in data processing and security
 - Notification of a personal data breach to the supervisory authority
 - Communication of a personal data breach to the data subject
 - Data protection impact assessment
 - Designation of the data protection officer
 - Certification
 - €20,000,000 or up to 4% of the annual worldwide turnover of the preceding financial year, whichever is the greater for failures relating to:
 - Principles relating to processing of personal data
 - Lawfulness of processing
 - Conditions for consent
 - Processing of special categories of personal data
 - Information and access to personal data
 - Information to be provided where personal data are collected from the data subject
 - Right of access by the data subject
 - Right to rectification
 - Right to erasure
 - Right to restriction of processing
 - Right to data portability
 - Automated individual decision-making, including profiling
 - Transfers of personal data to third countries or international organisations

Data Ethics

- Data ethics is concerned with the study and assessment of moral problems related to (generally personal and possibly sensitive) data along its lifecycle from collection or generation to usage
- Implicitly, GDPR is concerned with data ethics
 - While data ethics is an abstract topic and far removed from the initial concerns of becoming compliant with GDPR is the face of business, technical and time challenges it one that will become more important over time
- Data ethics includes the use of data process algorithms to derive data products in relation to which there may be moral and ethical concerns
- One objective of data ethics is to articulate and communicate what are morally good personal data processing solutions and approaches
- The increasing volume of personal data available and collected, both directly and indirectly – behaviour-type data – and associated data technologies – both data storage and data analysis tools and facilities - has extended the gap between what is possible in terms of personal data processing and what is should or legally can happen
- The data collectors have substantial power and influence
- The growth of free social media platforms means that information directly supplied and information derived from usage patterns is the commodity from which value can be obtained

Conclusioni

- The impact of GDPR cannot really be estimated or quantified at this stage
- There is a wider context for GDPR
- The range of data compliance regulations is only growing
- Achieving GDPR compliance has the potential to be very expensive, especially for larger organisations
- GDPR compliance should be addressed in the context of wider data governance
- Reuse existing methodologies where possible